

Basic Web Application Security Testing Guide

By Baba Shaheer

Introduction

This guide is designed for undergraduate students who are new to web application security testing. We'll focus on using Kali Linux to test vulnerabilities in the OWASP Broken Web App (BWA) project, which provides a safe, legal environment to practice ethical hacking skills.

Setting Up Your Environment

Step 1: Install VirtualBox

1. Download and install VirtualBox from [virtualbox.org](https://www.virtualbox.org)
2. Install the VirtualBox Extension Pack for better performance

Step 2: Download Kali Linux

1. Download Kali Linux (Virtual Machine image) from kali.org/get-kali/#kali-virtual-machines
2. Choose the VirtualBox version

Step 3: Import Kali Linux to VirtualBox

1. Open VirtualBox
2. Go to File → Import Appliance
3. Select the downloaded Kali Linux .ova file
4. Click “Next” and then “Import”
5. Default credentials:
 - Username: `kali`
 - Password: `kali`

Step 4: Download OWASP BWA

1. Download OWASP Broken Web App from sourceforge.net/projects/owaspbwa/files/
2. Download the latest .ova file (about 3GB)

Step 5: Import OWASP BWA to VirtualBox

1. Go to File → Import Appliance
2. Select the downloaded OWASP BWA .ova file
3. Click “Next” and then “Import”

Step 6: Configure Networking

1. Create a Host-Only Network:
 - Go to File → Host Network Manager
 - Click “Create” and note the network name (e.g., `vboxnet0`)
 - Make sure DHCP is enabled
2. Configure Kali Linux:
 - Right-click Kali VM → Settings → Network
 - Adapter 1: Select “Host-only Adapter” and choose the network you created
 - Adapter 2: Select “NAT” to allow internet access
3. Configure OWASP BWA:
 - Right-click BWA VM → Settings → Network
 - Adapter 1: Select “Host-only Adapter” and choose the same network

Step 7: Start Both VMs

1. Start OWASP BWA VM first
 - Login with username: `root` and password: `owaspbwa`

- Run `ifconfig` to see its IP address (note it down)
2. Start Kali Linux VM
 - Login with username: `kali` and password: `kali`
 - Run `ifconfig` to verify you can reach the internet
 3. Test connectivity:
 - In Kali, open a terminal and run: `ping [OWASP BWA IP]`
 - If successful, you're ready to begin testing

Basic Web Application Security Concepts

Before diving into testing, let's understand some key concepts:

Web Application Architecture

Web applications typically consist of: - **Frontend**: What users see (HTML, CSS, JavaScript) - **Backend**: Server-side code (PHP, Python, Java, etc.) - **Database**: Where data is stored (MySQL, MongoDB, etc.)

Common Vulnerabilities

The OWASP Top 10 represents the most critical web application security risks:

1. Injection
2. Broken Authentication
3. Sensitive Data Exposure
4. XML External Entities (XXE)
5. Broken Access Control
6. Security Misconfiguration
7. Cross-Site Scripting (XSS)
8. Insecure Deserialization
9. Using Components with Known Vulnerabilities
10. Insufficient Logging & Monitoring

Basic Testing with Kali Linux

Step 1: Reconnaissance

1. Open Firefox in Kali Linux
2. Navigate to the OWASP BWA IP address (e.g., `http://192.168.56.101`)
3. You'll see a list of vulnerable applications - explore the interface

Step 2: Accessing DVWA (Damn Vulnerable Web Application)

1. From the OWASP BWA homepage, click on DVWA
2. Login with:
 - Username: `admin`
 - Password: `password`
3. Go to "DVWA Security" and set security level to "Low" for beginners

Step 3: Testing SQL Injection

SQL Injection is a technique where attackers insert malicious SQL code into inputs.

1. In DVWA, click on "SQL Injection" in the left menu
2. In the User ID field, try entering: `1` (a normal query)
 - See the legitimate result for User ID 1
3. Now try: `1' OR '1'='1`
 - This should display all users in the database
4. Try: `1' UNION SELECT user,password FROM users #`
 - This might reveal usernames and passwords

Step 4: Testing Cross-Site Scripting (XSS)

XSS allows attackers to inject malicious scripts into web pages.

1. Click on “XSS (Reflected)” in the left menu
2. In the “What’s your name?” field, enter: `<script>alert('XSS Attack!')</script>`
3. Click “Submit”
4. If vulnerable, you’ll see an alert box pop up

Step 5: Using Burp Suite

Burp Suite is a powerful web vulnerability scanner included in Kali.

1. Open Burp Suite from Applications menu or terminal: `burpsuite`
2. Keep the default settings and click “Start Burp”
3. Go to “Proxy” tab → “Options” → Verify proxy is running (usually 127.0.0.1:8080)
4. Configure Firefox to use the proxy:
 - Open Firefox → Menu → Preferences → Network Settings
 - Select “Manual proxy configuration”
 - HTTP Proxy: 127.0.0.1, Port: 8080
 - Check “Use this proxy server for all protocols”
5. In Firefox, visit any page on DVWA
6. In Burp Suite, go to “Proxy” → “Intercept” to see the requests
7. You can modify requests before forwarding them to discover vulnerabilities

Step 6: Directory Scanning with Dirb

Dirb helps discover hidden directories on web servers.

1. Open a terminal in Kali
2. Run: `dirb http://[OWASP BWA IP]/dvwa/`
3. Dirb will scan and show potentially interesting directories

Step 7: Testing Command Injection

Command injection allows attackers to execute system commands.

1. In DVWA, click on “Command Injection”
2. Enter a legitimate IP to ping: `127.0.0.1`
3. Now try: `127.0.0.1; ls -la`
4. The semicolon allows you to execute a second command (`ls -la`)
5. Try: `127.0.0.1; cat /etc/passwd`
 - This might reveal system user information

Practicing with bWAPP

bWAPP (buggy Web Application) offers more advanced vulnerability testing.

1. From OWASP BWA homepage, click on bWAPP
2. Login with:
 - Username: `bee`
 - Password: `bug`
3. From the dropdown menu, select a vulnerability (e.g., “SQL Injection”)
4. Set security level to “low” and click “Hack”

Testing SQL Injection in bWAPP

1. Select “SQL Injection (GET/Search)” from the dropdown
2. In the search field, enter: `a' OR 1=1 #`
3. Click “Search”
4. You should see all entries in the database

Testing Cross-Site Request Forgery (CSRF)

1. Select “CSRF (Change Password)” from the dropdown
2. Analyze how the form works (using Burp Suite to capture the request)
3. Create a malicious HTML page that automatically submits a form to change the password

Using OWASP ZAP

OWASP ZAP is an easy-to-use integrated penetration testing tool for finding vulnerabilities.

1. Open ZAP from Applications menu or terminal: `zaproxy`
2. Click “Automated Scan”
3. Enter the URL: `http://[OWASP_BWA_IP]/dvwa/`
4. Click “Attack”
5. ZAP will spider the site and perform automated tests
6. Review the “Alerts” tab for discovered vulnerabilities

Documentation and Reporting

An important skill in security testing is documenting your findings:

1. For each vulnerability you discover, document:
 - Vulnerability name and type
 - Where it was found (URL, parameter)
 - How to reproduce it (exact steps)
 - Potential impact
 - Suggested fix
2. Include screenshots to demonstrate the vulnerability
3. Classify by severity (Critical, High, Medium, Low)

Ethical Considerations

Always remember: - Only test applications you have permission to test - Never use these techniques on real websites without authorization - The skills you learn should only be used ethically and legally - Your goal is to help improve security, not to exploit vulnerabilities

Resources for Further Learning

- OWASP Testing Guide
- PortSwigger Web Security Academy (Free, interactive labs)
- Burp Suite Documentation

Remember, the key to becoming proficient in web application security testing is consistent practice and continuous learning. Good luck!